DOC-04 | 權限與安全矩陣

水電工程管理系統 | 正式開發交付規格草案 v1.0 | 2026-11-10

狀態：僅供設計與審查；未實作、未部署、未進行安全測試。依據 P0.3–P0.9 已討論規則。

01 | 目的與權限模型

採 RBAC（Owner／Admin／Member）搭配細項權限授予／拒（permission_grants）。明確拒絕優先於一般允許；組織隔離與帳號有效狀態是所有權限的先決條件。權限以後端與資料庫 RLS 強制執行，前端隱藏功能僅是介面輔助。

層次	驗證條件	拒絕原則
身分	已登入且帳號有效	未登入回 401
組織	有效 organization_members 關係	跨組織拒絕；避免揭露資源存在
功能	角色預設 + 細項授權	明確 deny 優先；缺權限拒絕
資源	資源組織、狀態與業務約束	不可越權操作他人資源
交易	金額／數量／狀態合法、版本、冪等	失敗回滾保留安全事件

02 | 角色定義與授權原則

角色	預設職責	限制
Owner 老闆	組織管理、成員與授權管理；擁有管理權	敏感資料存取仍需受審計；不可繞過組織隔離
Admin 管理者	管理日常工程、排程、派工	財務、採購核准、敏感資訊需個別授權
Member 員工	一般工程看、回報、個人出勤、報修	不得預設存取成本、薪資、門禁或核准權

不得刪除／停用組織最後一名有效 Owner。Owner 轉移需重新驗證、雙方授權確認及稽核。

03 | 功能權限矩陣

符號： 基礎允許；授權 = 需顯式 permission_grant；—＝預設拒絕。最終仍受資料歸屬及狀態規則約束。

功能／操作	Member	Admin	Owner
一般工程、任務、行程看	✓	✓	✓
工程與任務新增／編輯	授權	✓	✓
施工回報與照片上傳	✓	✓	✓
本人打卡／更正申請	✓	✓	✓
審核他人出勤更正	—	授權	授權
建立客戶與維修案件	✓	✓	✓
維修派工、結案與重開	授權	✓	✓
庫存查詢／領料申請	✓	✓	✓
庫存正式過帳與盤點調整	授權	授權	授權
建立採購申請	✓	✓	✓

一般採購核准（≥3,000）	授權	授權	授權
緊急採購（單次≤5,000）	授權	授權	授權
採購事後核對	—	授權	授權
查看報價**售**價與合約	授權	授權	授權
查看內部成本、利潤與供應商付款	授權	授權	授權
建立請款、收款與退款	授權	授權	授權
零用金補充申請	✓	✓	✓
零用金補充核准與撥款	—	授權	✓
查看門禁密碼／敏感存取資訊	授權	授權	授權
管理組織成員與權限	—	授權	✓
匯出敏感資料與看完整稽核	—	授權	授權

04 | 權限代碼與資料存取

權限代碼（建議）	作用
projects.write	新增／修改工程與任務
attendance.review	審核出勤更正
inventory.post	正式庫存過帳
procurement.approve	一般採購核准
procurement.emergency	緊急採購
procurement.reconcile	緊急採購事後核對
finance.read	查看財務資料
finance.cost.read	看內部成本與毛利
finance.write	建立請款／收款／退款
petty_cash.approve	核准零用金補充
petty_cash.disburse	確認實際撥款
site_secrets.read	查看門禁／鑰匙盒資訊
members.manage	管理成員及其授權
audit.read	閱稽核事件
exports.sensitive	匯出敏感資料

權限命名與 API／RLS 實作時須統一維護一份權限字典，不可在前端、後端與 SQL 各自定義不同字串。

05 | 採購與零用金職責分離

一般採購：最終應付金額 ≥ NT$3,000 須事前核准。緊急採購：單次 ≤ NT$5,000，每人每日 ≤ NT$10,000（Asia/Taipei），需事由、授權及事後核對。超額不得藉**拆**單規避。

建議原則：申請人不可自行核准同筆一般採購；緊急採購事後核對人不得與購買人相同。小團隊如確需例外，須由 Owner 以明確政策授權並保留例外原因及完整稽核；此例外尚待核定。

零用金補充：申請→審核→撥款→確認收款，分別記錄操作人、時間、金額與憑證；核准不等於已撥款。

06 | 敏感資料分級與保護

資料等級	範例	控制要求
一般	任務、工程進度、一般施工回報	有效組織成員依權限可讀
□□	□□□□□□□□□□□□□□□□	業務授權、避免過度匯出
□□	成本、薪資、收款、退款、客戶個資	細項授權、存取日誌、限時匯出
高度敏感	門禁碼、鑰匙盒碼、秘密金鑰	分離儲存、加密、最小可見、不得出現在日誌

site_access_secrets 應與 sites 分表儲存；應用程式加密金鑰由受控環境管理。施工照片與 PDF 採私有儲存、授權後短效連結；匯出時移除非必要 EXIF 定位資訊。

07 | RLS、API 與稽核安全契約

- 每筆有組織歸屬的資料，讀寫前均驗證 organization_id 與有效 membership；外鍵亦需檢查同組織。
- RLS 預設拒絕，僅授權策略可開放；Service Role 僅供可信後端使用，絕不可送至瀏覽器。
- API 必須重新驗證授權；不能相信前端送來的 role、organization_id、approved_by 或 cost_visibility。
- 權限異動、採購核准、退款、門禁存取、敏感匯出及資料刪除應記錄 audit_events；不得記錄明文密碼或完整門禁碼。
- audit_events 採不可變記錄，保留行為者、組織、資源、時間、動作、結果及必要的遮罩差異。
- Idempotency-Key 需綁定組織、使用者、操作與請求摘要；相同 key 不同內容回傳衝突。
- 對失敗登入、越權嘗試、批量匯出與異常頻率設定安全事件、速率限制及告警。

08 | 測試與驗收案例

案例	情境	預期結果
SEC-01	未登入呼叫受保護 API	401
SEC-02	跨組織讀取工程／客戶／財務	拒絕且不洩漏資料
SEC-03	員工自行提高權限	拒絕、記錄安全事件
SEC-04	Admin 未授權讀取成本	拒絕
SEC-05	未授權讀取門禁碼	拒絕，無明文日誌
SEC-06	員工嘗試核准自己採購	依職責分離政策阻
SEC-07	同時緊急採購造成每日超額	交易阻，無超額承諾
SEC-08	同筆請款重送收款	僅建立一次有效交易
SEC-09	私有照片直接公開網址存取	拒絕
SEC-10	撤銷成員權限後沿用舊連線	敏感操作再次驗證而拒絕
SEC-11	最後一位 Owner 被移除	拒絕
SEC-12	敏感匯出	需授權並留稽核
SEC-13	服務金鑰出現在前端 bundle	建置阻
SEC-14	修改歷史 audit_events	拒絕

SEC-15	不同組織同 ID 引用	拒絕跨組織關聯

09 | 未定案政策與實作前阻擋條件

待決定：採購申請人與核准人是否可在小團隊例外同人；管理者對敏感財務資料的預設可見性；個資保存期限及刪除／匿名化政策；敏感匯出審批機制；權限變更後快取失效時間。這些不可擅自標記為使用者已批准。

開發前須將權限字典、角色預設、API 操作及 RLS Policy 建立一對一映射；上線前需完成跨組織滲透測試、負面授權測試、金鑰掃描、備份還原演練及安全事件驗證。

10 | 文件追溯與交付狀態

關聯 DOC-01（需求）、DOC-02（API）、DOC-03（資料庫）。後續 DOC-05 應收錄 SEC-01～SEC-15 測試；DOC-06 需將每項控制拆為可驗收工作票；DOC-07 定義金鑰、備份及復原維運程序。

交付狀態：本文件為可編輯設計規格；尚未產出實際 RLS SQL、完整授權測試程式，也未修改任何正式系統。